

XSS与字符编码的那些事儿 ---科普文

0x_Jin 2013-10-21 14:25:00

目录

- 0x00 · 基本介绍
- 0x01 · html 实体编码
- 0x02 · 新增的实体编码 实体编码变异以及浏览器的某些工作原理！
- 0x03 · javascript 编码
- 0x04 · base64 编码
- 0x05 · 闲扯

0x00基本介绍

提起XSS 想到的就是插入字符字符编码与各种解析了！

这也就是各种xss编码插件跟工具出世的原因！之前不懂浏览器是如何对我们编码过的代码进行解析的时候就各种编码 各种插 没把编码还原就算了 还原了就算运气好！后来到PKAV经过二哥和短短的调教后才算是弄清楚现在也算是运用自如了把！

现在介绍一下在xss中最经常用到的编码

html实体编码(10进制与16进制):

如把尖括号编码[<] -----> html十进制: < html十六进制: <

javascript的八进制跟十六进制:

如把尖括号编码[<] -----> js八进制: \74 js十六进制: \x3c

jsunicode编码 :

如把尖括号编码[<] -----> jsunicode: \u003c

url编码 base64编码:

如把尖括号编码[<] -----> url: %3C base64: PA==

0x01 html实体编码

那么我们可以在这里 闭合双引号 写事件: `onerror=[html language="实体编码"][/html][/html]`

比如我现在弹个窗:

```

```

原code:

```

```

这里我用的是html十进制编码 也可以使用十六进制的html实体编码！

但是为什么这里我没有用jsunicode 以及 js八进制跟js十六进制呢！

浏览器是会不会在html标签里解析js中的那些编码的！所以我们在onerror=后面放js中的编码是不会解析 你放

大多数网站是不会&#号的，如果过滤了怎么办呢？

那么再来讲一下另外一个案例：[00]

腾讯新闻：

证券报道系列之0
证券报道系列之1
证券报道系列之2
证券报道系列之3
证券报道系列之4
证券报道系列之5
证券报道系列之6
证券报道系列之7
证券报道系列之8
证券报道系列之9

首页 上页 下页 尾页 0/0 转到第 页 GO

源码如下：[00]

```
<view-source:x...&searchtype_yjbg=yjg&searchvalue_yjbg=wooyun>
4 <head>
5 <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
6 <meta http-equiv="X-UA-Compatible" content="IE=EmulateIE7" />
7 <title>研究报告_证券频道_腾讯网</title>
8 <style>
9 body{font-size:12px;}
10 .main ul{list-style:none;}
11 .ffy{text-align:left;}
12 .clear{clear:both;}
13 .fanye{height:30px;line-height:30px;}
14 .fanye li{float:left;margin-right:5px;display:inline;font-family: Tahoma;color:#333;}
15 .fanye li a{color:#333;}
16 .fanye li a:hover{color:#cc0000}
17 .fanye li .yebg{width:34px;background:url(/img/bt.gif) no-repeat 0px 6px;text-align:center;height:25px;*height:25px;}
18 #pagenum{width:50px;}
19 </style>
20 </head>
21 <script>window.onerror = function(){return true;};</script>
22 <body>
23 <div class="main">
24 腾讯新闻:<br>
25 <ul>
26 <li><a href="#">证券报道系列之 0</a></li><li><a href="#">证券报道系列之 1</a></li><li><a href="#">证券报道系列之 2</a></li><li><a href="#">证券报道系列之 3</a></li><li><a href="#">证券报道系列之 4</a></li><li><a href="#">证券报道系列之 5</a></li><li><a href="#">证券报道系列之 6</a></li><li><a href="#">证券报道系列之 7</a></li><li><a href="#">证券报道系列之 8</a></li><li><a href="#">证券报道系列之 9</a></li>
27 </div>
28 <div class="ffy clear">
29 <div class="fanye">
30 <ul>
31 <li><div class="yebg">首页</div></li>
```

由于页面对单引号 & 符号 以及 #符号过滤！但是html中可以识别html实体编码！但是实体编码是由&#组成

这个时候&#已经被过滤 我们只能通过url编码来对 & # 两个符号进行编码！再让浏览器解码成 &# 然后拼接html16进制编码！

解码后：我们的提交值为：

```
' ,alert(1)'
```

href代码为：

```
<a href="javascript:location=' /? 3 nbn?offset='+document.getElementById('pagenum').value+'&searchtype_yjbg=yjjg&searchvalu
```

ps:在之前说了html标签中识别html实体编码，并且会在html页面加载时会对编码进行解码！那么' 已经在点击过程中执行javascript代码 这个时候由于html里'被解析成单引号但是没闭合 这个时候js被解析成了字符串单引号但是不能闭合之前的引号 因为现在是把我们提交的编码了的单引号 当成字符串来显示 href里的 href链接里的地址是javascript伪协议，我们现在点击的时候 会执行里面的代码 关键来了 这个时候被再次解析 这个时候就没任何过滤规则来过滤它 程序也没那么智能 之前当做字符串的单引号起作用了 javascript被浏览器解析成了什么 他就带入进去！就在这个时候我们的字符串单引号就成功的闭合了！当点击go时 我们

上面这个例子讲了html编码 以及特殊情况下的编码那么再讲下当你的输入点存在于script标签中的时候！我们

既然知道是如何解析的了 那么便又有了以下新的想法！

0x02 新增的实体编码，变异以及浏览器的某些工作原理

通常程序做 XSS 防御的时候会考虑到一些 HTML 编码的问题，会拦截或转义 " 这样的东西 那么我的双引号

但基础这种黑名单方式可能出现的问题：

1. 不认识 HTML5 新增的实体命名编码,如

```
&colon; => 「冒号」  
&NewLine; => 「换行」
```

```
case: <a href="javasc&NewLine;ript&colon;alert(1)">click</a>
```

2.对 HTML 编码的解析规则不够熟悉，就像十进制和十六进制编码的分号是可以去掉的。

还有，数字编码前面加「0」，这也是一条很好的绕过 WAF 的向量。

如下图（我去掉了后面的分号 另外在每个数字前加了一个零）：



这句代码能够执行么？

不知道那些不是很清楚浏览器工作原理的基友，在刚开始有没有怀疑这段代码能不能执行！

起码我最开始 怀疑过！即使编码被解析回来了 换行了还能执行么！

当时就去问了我的好基友 XX大神[一位跟短短一样拥有着跟常用不一样的思维 在我们看来是很不同于正常人

然后大神给了我一份比较详细的浏览器工作原理 很长很长！

我就把最主要的copy下来贴上吧！

解析器 - 词法分析器 Parser - Lexer combination

解析可以分为两个子过程——语法分析及词法分析

词法分析就是将输入分解为符号，符号是语言的词汇表——基本有效单元的集合。对于人类语言来说，它相

语法分析指对语言应用语法规则。

解析器一般将工作分配给两个组件——词法分析器（有时也叫分词器）负责将输入分解为合法的符号，解析结构，从而构建解析树，词法分析器知道怎么跳过空白和换行之类的无关字符。

然后我的理解是这样的：

```
<a href="javasc&NewLine;ript&colon;alert(1)">click</a>
```

首先html编码被还原出来 然后就成了换行 跟冒号

```
<a href="javasc  
ript:alert(1)">click</a>
```

为什么换行后还能够执行 是因为浏览器中的解析器中词法分析器 起的作用会跳过空白跟换行之类的无效字符

然后就构造成了一个完整的语句

```
<a href="javascript:alert(1)">click</a>
```

代码执行!

看完那些之后瞬间心里觉得原来跟原理性相关的东西真的很重要！能够让你写 xss payload更加灵活！

0x03 javascript编码

javascript中只识别几种编码：Jsunicode js8进制 js10进制

就拿下面这个例子来讲吧！

第一种情况 你输入的值存入某个变量 然后最后出现在某个能把字符串当做js代码来执行的函数里！

现在我们来看看 输出是什么效果！

我就用chrome console来演示吧！



看到了把 经过js的解码 我们的代码又还原回来了 并且注入到了网页中！这时候代码执行！成功弹窗！

在js中是可以用jsunicode js16进制 js8进制的！

为什么这里不用16进制 跟unicode编码！是因为 八进制的相对而言最短！

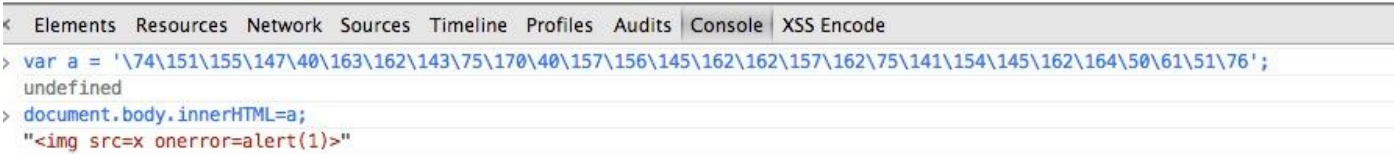
在xss中字符数的长短 也是一个很重要的问题！越短越好！

在asp的站中插XSS代码的时候，存储型 会因为你数据库中字段的长度不够

而存不进去 然后报错！这种情况经常发生！所有养成用最少的字符 来达到你的目的 是最好的！

既然提到了js中的十六进制编码 跟js中的unicode编码 那么也上两张图吧！

十六进制在js中是\x[16hex] 来表示的 如：< \x3c

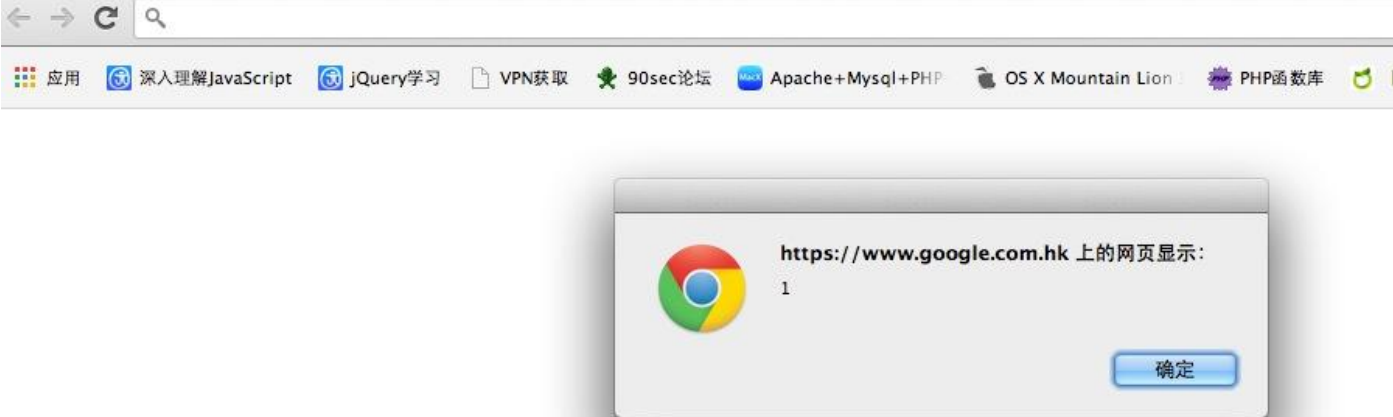


大家看到跟八进制的用法也是一样的！只不过多了一个字符X 虽然我很喜欢这个字符 但是我更喜欢八进制的

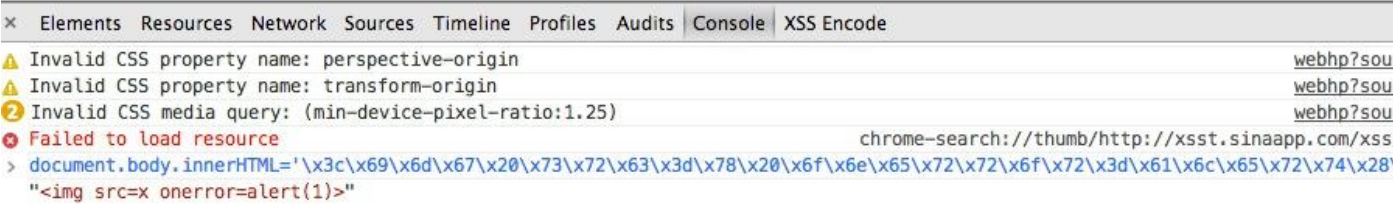
下面再说说jsunicode编码：

他的表示方式是这样的：\uxxxx \uxxx < 转码后: /u003c

上图：



系统偏好设置



0x04 base64编码

到目前为止 我遇到使用base64编码的情况 大多数是这样！

```
<a href="可控点">
<iframe src="可控点">
```

在这种情况下 如果过滤了 `<> ' " javascript` 的话 那么要xss可以这样写 然后利用base64编码！

```
<a href="data:text/html;base64, PGltZyBzcmM9eCBvbmVycm9yPWFsZXJ0KDEpPg==">test</a>
```

这样当test A链接点击时 就会以data协议 页面以html/text的方式解析 编码为base64 然后单点击a链接时的

```
<img src=x onerror=alert(1)>
```

然后成功弹窗！

如下图：



其实好多阻挡在面前的就是那些原理性的东西！懂了就好了！

看着二哥挖掘反射型xss 让我感觉很像js代码审计！

用二哥的话来说，首先你js的功底得比写js的人功力要高 然后你就比较容易挖掘到xss!所以我感觉js比xss来t
js 才练就今天的功力！所以我特别坚信这句话！

一般测试xss首先我会先测试一些反射型！提交几个非法字符 然后看过滤成什么了！然后再打开chrome co
网页所引用文件中的一些关键字！比如这个输入框的id =xxxx 然后我就一直追踪下去！如果某个数组 或者变
直追踪下去 一直找到源头！把代码都看一边 如果能绕过的话 自己在chrome稍稍调试下就能挖掘出来了！

当然这种方法也是二哥教！二哥跟短短一直都是我膜拜的对象！短短跟我讲了讲 浏览器的解析，二哥讲了 d
完的一些技巧！

顿时赶脚 挖掘XSS是那么的容易！

附XSS Encode插件打包

END

评论

- 瞓

瞓睡龙

2013-10-21 14:27:00

建议结合此篇观看：<http://drops.wooyun.org/tips/147>
另：小伙伴，那个XSS Encode能共享不：)
- 0

Ox Jin

2013-10-21 14:58:35

额 xsser们 需要？ 那个如果有的话 我就传一份把！@瞓睡龙
- N

NgInx

2013-10-21 14:58:38

兄弟啊，顶你一下。
- 0

Ox Jin

2013-10-21 15:20:41

XSS Encode 本身写着自己用的 所以根据自己的分辨率写的
<http://pan.baidu.com/s/1GHkPp>
- 瞓

瞓睡龙

2013-10-21 15:28:38

嗯，上传了一份在drops方便下载，已在最后附上。
- B

big_ face

2013-10-21 22:08:34

必须需要,菜鸟求一份
- Z

ziwen

2013-10-22 21:56:52

啊哈原来是你 还记得我么
- 大

大隐

2013-10-23 12:13:51

好
- 海

海盗湾V

2013-10-23 19:22:23

[<]的URL和base64编码写错了。
url:%3C base64:PA== @瞓睡龙
- 瞓

瞓睡龙

2013-10-23 19:29:32

哈，感谢指正，已修改~
- N

Nicky

2013-10-24 22:09:08

好文章，求私信QQ交流~
- C

c2y2

2013-10-29 00:39:37

S

是还蛮科普的....

猪

[猪头子](#) 2014-01-23 11:37:06

这么多惊叹号看着还是有一点惊悚的。。

H

[hkAssassin](#) 2014-01-24 13:23:21

好文章，能不能把大神分享给你的那个浏览器解析过程的文章也给我分享一下我看看.....

O

[Ox Jin](#) 2014-01-26 23:10:21

浏览器解析过程的话 google一下 现代浏览器工作原理

L

[Lenwood](#) 2014-02-10 16:38:03

data:image/png;base64,iVBORw0KGgoAAAANSUhEUgAAABAAAAQCAQAAAC1+jfqAAAAqUIEQ
RnS9QbCxtJg6Z7CzE9lTiIXyUb3C8EULixDIMM8Zt4kcDfxM5A45U+cgeXnC1tREgkzAgob3hiq3CU
2IVDksen9GH7Z9hA5E6uxABMJyCHDMCEGHzugLQPPIBCBNGq+5YtpnGw1Bv+te15ypljTpVzdak5
JRUErkJggg==

暗

[暗影](#) 2014-07-16 18:56:33

编码的 网站多少啊

H

[hzh4k](#) 2014-08-17 11:46:35

alert('xss')
被转换成全角的 是否还能绕过

路

[路人甲](#) 2014-09-15 17:29:12

最近用得谷歌浏览器几乎所有的方法都会被The XSS Auditor 所拒绝呀 请问这是为什么 chrome太叼没法

小

[小飞](#) 2014-11-11 17:53:12

好文章，但是为何语气如此霸气

B

[Bug](#) 2014-11-28 14:56:33

原文是否有错？

start-----

原code:

这里我用的是html十进制编码 也可以使用十六进制的html实体编码！

但是为什么这里我没有用jsunicode 以及 js八进制跟js十六进制呢！

浏览器是会不会在html标签里解析js中的那些编码的！所以我们在onerror=后面放js中的编码是不会解析 你

end-----

在onerror中可以写js代码的，所以下代码

在浏览器看来，首先会先进行HTML解码，紧接着进行JS解码，因此，可以成功弹窗。

A

Aug0st 2014-12-04 19:33:50``

这样貌似弹不了！html标签解码是分标签的，不是每个标签都对实体解码的大哥！

0

0x_Jin 2014-12-06 20:32:19``

这样弹不了？你确定？

<http://jsbin.com/jeyinabaki/1>

0

0x_Jin 2014-12-06 20:39:28

：) 那里确实有问题 js的编码是会被解码的。

onerror里的内容是当js解析 而js里 是能解析js编码的。

但是不能全部编码只能编码函数名。如果全部编码是会出错的

能看到这里的小伙伴请改正一下

R

rheladmin 2015-04-07 16:54:43

在这种情况下 如果过滤了<> ' " javascript 的话 那么要xss可以这样写 然后利用base64编码！

`<a href="data:text/html;base64,PGltZyBzcmM9eCBvbmVycm9yPWFsZXJ0KDEpPg==">test</a>`

请问下<> ' " javascript ，这种方法利用是不是就有问题<a href=" , 这个当中<,"不是就被注释了

爱

爱梅小礼 2015-06-14 00:12:06`<a href="data:text/html;base64,PGltZyBzcmM9eCBvbmVycm9yPWFsZXJ0KDEpPg==">test</a>`

请问这种XSS方式有没有什么利用场景？还是只是弹个框框而已。我认为如果不能在目标域执行js，那么XSS

进

进击的zjx 2015-07-03 11:03:23

后排顶jin神

W

watchdoge 2016-03-29 23:34:58

现在貌似浏览器会将换行符替换成空格 亲测chrome下不能用换行绕过了

路

路人甲 2016-04-20 17:41:22

@rheladmin 我也有这个疑问。我不会说话，我感觉怎么这么多人喜欢自己骗自己，一般web程序都是用不过，这些意义都不大

路

路人甲 2016-05-17 10:57:03

大神好喜欢打感叹号

立

立志成为厨神的男人 2016-06-01 15:40:23

感谢分享 茅塞顿开 困扰我许久的编码问题